VENDOR SECURITY QUESTIONNAIRE

Information Security Due Diligence Assessment

Issued by: Apex Capital Partners — Vendor Risk Management Office
Date Issued: June 2025 | Response Required By: July 15, 2025
Vendor: NexaTech Solutions Inc. | Engagement Ref: ACP-VSQ-2025-0041

INSTRUCTIONS FOR COMPLETION

Please provide written answers to all 30 questions. Where documentary evidence is available (e.g., certification copies, audit reports), attach as appendices and reference by question number. Answers should reflect your current operational state as of the date of submission.

Responses will be reviewed by Apex Capital Partners' information security team. Follow-up clarification may be requested. This document is classified CONFIDENTIAL and should not be shared externally without written consent from Apex Capital.

Section A — Data Security (Q1–Q5)

Q1	Data Security	What data classification tiers does your organisation use, and what types of data fall into your most sensitive category?
Answer		
Source		
Q2	Data Security	What encryption standard is applied to data at rest, and which systems are in scope?
Answer		
Source		

Q3	Data Security	What TLS version is enforced for data in transit, and are older protocol versions disabled?
Answer		
Source		
Q4	Data Security	How are encryption keys managed and how frequently are they rotated?
Answer		
Source		
Q5	Data Security	What is your policy for encrypting email communications containing sensitive data?
Answer		
Source		

Section B — Access Control (Q6–Q10)

Q6	Access Control	Is Multi-Factor Authentication (MFA) mandatory for all users, and what authentication methods are acceptable?
Answer		
Source		
Q7	Access Control	What are your password complexity and rotation requirements?
Answer		
Source		
Q8	Access Control	How is privileged access managed and monitored within your environment?

Answer		
Source		
Q9	Access Control	What is the session timeout policy for your administrative consoles and web applications?
Answer		
Source		
Q10	Access Control	How is role-based access control implemented, and how frequently are access rights reviewed?
Answer		
Source		

Section C — Incident Response (Q11–Q14)

Q11	Incident Response	How does your organisation classify security incidents by severity, and what are the response SLAs for each tier?
Answer		
Source		
Q12	Incident Response	What is your breach notification timeline under GDPR, and who is responsible for notifying regulators?
Answer		
Source		
Q13	Incident Response	Do you maintain an external forensics retainer, and if so, with which provider?
Answer		

Source		
Q14	Incident Response	Who comprises your Incident Response Team and what is the on-call arrangement?
Answer		
Source		

Section D — Vendor & Third-Party Management (Q15–Q18)

Q15	Vendor Management	How do you assess the security posture of third-party vendors before granting them access?
Answer		
Source		
Q16	Vendor Management	Which cloud infrastructure providers do you use, and in which geographic regions do you process data?
Answer		
Source		
Q17	Vendor Management	Do you maintain a sub-processor register? Please identify your key data sub-processors.
Answer		
Source		
Q18	Vendor Management	What contractual security obligations are placed on vendors with access to customer data?
Answer		
Source		

Section E — Business Continuity & DR (Q19–Q22)

Q19	Business Continuity	What are your Recovery Time Objective (RTO) and Recovery Point Objective (RPO) for critical services?
Answer		
Source		
Q20	Business Continuity	How is your infrastructure architected for high availability, and across how many availability zones?
Answer		
Source		
Q21	Business Continuity	How frequently are backups performed, and how is backup integrity verified?
Answer		
Source		
Q22	Business Continuity	How often is your disaster recovery plan tested, and to whom are the results reported?
Answer		
Source		

Section F — Compliance & Certifications (Q23–Q26)

Q23	Compliance	Which security frameworks and certifications does your organisation hold, and when were they last renewed?
Answer		
Source		
Q24	Compliance	How frequently do you conduct external penetration testing, and when was the most recent test?

Answer		
Source		
Q25	Compliance	How do you handle personal data subject rights requests (e.g., access, deletion) under GDPR and CCPA?
Answer		
Source		
Q26	Compliance	Is your SOC 2 Type II report available to customers, and what Trust Services Criteria does it cover?
Answer		
Source		

Section G — Physical Security (Q27–Q28)

Q27	Physical Security	What physical access controls are in place at your office and data centre locations?
Answer		
Source		
Q28	Physical Security	What is your process for securely disposing of devices containing sensitive data?
Answer		
Source		

Section H — Security Training (Q29–Q30)

Q29	Security Training	What security awareness training is mandatory for employees, and how frequently is it conducted?

Answer		
Source		
Q30	Security Training	How do you test employee resilience to phishing attacks, and what happens when employees fail a simulated test?
Answer		
Source		

DECLARATION

I confirm that the information provided in this questionnaire is accurate and complete to the best of my knowledge as of the date of submission.

Authorised Signatory Name:	Title / Role:
Signature:	Date: